PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

# Violations de données applicatives

03-1330 CERT-FR - Violations de données applicatives, retour d'expérience — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

**À RETENIR**

1. Les incidents d'exfiltration sont en hausse avec 196 cas en 2025 contre 130 en 2024.
2. La plupart des fuites n'exploitent pas de vulnérabilité technique mais utilisent des identifiants légitimes ou des données exposées.
3. L'authentification par simple couple login et mot de passe est considérée comme obsolète en 2026.

## Constat du CERT-FR

| Notion | À retenir |
|---|---|
| Phénomène en hausse | Incidents d'exfiltration : **196** en **2025** contre **130** en **2024**, sans ciblage particulier : **toute entité** peut être touchée. Attaquants rapides (quelques minutes), hors heures ouvrées. |
| Modes opératoires | Réutilisation d'**identifiants légitimes**, **ingénierie sociale**, **exposition de données** sans contrôle, ou **infostealers** via faux logiciels. |
| Impacts | Données fusionnées/croisées revendues, exploitées pour la **fraude** ou diffusées pour la **déstabilisation**. |

## Risques et scénarios de violation

| Notion | À retenir |
|---|---|
| Types d'impacts | **Divulgations unitaires** (fort enjeu, préjudice important) vs **violations de masse** (dommages moindres, grand nombre, nourrissent fraudes personnalisées). |
| Quatre scénarios | **Usurpation d'identifiants**, **accès direct aux données** (port exposé, S3, sauvegarde), **collaborateur interne malveillant** (comptes non révoqués) ou **vulnérabilité applicative**. |
| Hors du périmètre | **Extractions de bases**, **traitements sous-traités** et **supports mobiles non effacés** ; cycle de vie à étudier avec le **délégué à la protection des données**. |

## Les 10 principes de sécurisation

| Notion | À retenir |
|---|---|
| Gestion des données | Recenser les données, formaliser les flux, chiffrer (**LUKS**, **Clevis**, **BitLocker**) et utiliser des données **simulées**, **pseudonymisées** ou **anonymisées** hors production. |
| Accès utilisateurs | **Moindre privilège**, accès restreint aux fonctions d'administration, usage **limité en heures non ouvrées** (ex. **23 h-5 h**), **comptes partagés** proscrits, comptes inactifs désactivés. |
| Limitation exposition | Filtrer (L3/L4/L7), séparer les services (nom d'hôte), utiliser l'adressage **RFC 1918** et l'en-tête `X-Forwarded-For`. |
| Authentification | En **2026**, le login/MDP est obsolète. Utiliser **passkeys**, **MFA** (guide ANSSI) ou le standard **DBSC** (Chrome, mi-2026). |
| Environnement hébergement | Architecture en **3 couches** (DMZ, middleware, stockage), services locaux sur `127.0.0.1` et administration via **postes dédiés**. |
| Traçabilité | Chaque action attribuée à un utilisateur et une adresse source. Journaux centralisés, conservés **au moins 6 mois**, format `Syslog IETF`, horodatage **ISO 8601** à la milliseconde, fuseau unique (UTC). |
| Supervision | Signaler les comportements anormaux (ex: **Tor**, voyage impossible) via des règles au format **Sigma**. |
| Réactions automatiques | Utiliser des **seuils métiers** et des actions d'endiguement (blocage source, révocation de jetons) via les fiches **InterCERT-France**. |

## Vérifier la sécurité de l'application

- ☐ **Auditer** l'application avant la mise en production puis dans la durée par le maintien en condition de sécurité.
- ☐ **Tenir** un inventaire ou une **SBOM**.
- ☐ **Faire** une veille de vulnérabilités.
- ☐ **Mesurer** l'exposition au moins **chaque mois** (outils **EASM**) ; correctifs des frontaux au moins mensuels.
- ☐ **Ne jamais laisser** une mesure temporaire devenir définitive sans correction de la faille.

## Aide à la vérification et à l'homologation

| Outil / Action | Cible / Condition |
|---|---|
| Audits qualifiés **PASSI** | Entités publiques et régulées ; Aide à la vérification |
| Services du **CERT-FR** | Accessibles par le **ClubSSI** ; Aide à la vérification |
| **SILENE** | Entités publiques et régulées ; Pour l'exposition |
| **ADS** | Entités publiques et régulées ; Pour **Active Directory** |
| **Homologation** de chaque application publique | Obligatoire : autorités administratives (**RGS**), systèmes de l'État (**décret 2022-513 du 8 avril 2022**). Analyse de risque intégrant la **confidentialité des données**, couplée à l'**AIPD** si risque élevé. |

## Pièges et confusions

⚠ Croire que les fuites de données exploitent majoritairement des vulnérabilités techniques.
⚠ Penser qu'un attaquant commence directement par une extraction massive sans consulter de fiches avec un compte légitime.
⚠ Considérer que le couple login et mot de passe est encore une méthode suffisante en 2026.
⚠ Attendre le remplacement d'une application ancienne pour appliquer des mesures de réduction de risque.
⚠ Confondre une divulgation unitaire à fort enjeu avec une violation de masse aux dommages moindres.

## Sigles et définitions

**Violation de données personnelles** : Incident de sécurité causant la destruction, la perte, l'altération, la divulgation ou l'accès non autorisé à des données à caractère personnel.

**Infostealer** : Code malveillant collectant les identifiants enregistrés dans les navigateurs et les cookies de session.

**Insider** : Collaborateur interne malveillant, en conflit, vénal ou contraint, divulguant des données auxquelles il a légitimement accès.

**RBAC** : Role Based Access Control attribuant les droits à des groupes métiers.

**WAF** : Pare-feu applicatif filtrant les requêtes Web selon leur contenu.

**SBOM** : Software Bill Of Materials, liste des composants d'un logiciel en format technique.

**AIPD** : Analyse d'impact relative à la protection des données pour les traitements à risque élevé.

## Auto-test

1. Combien d'incidents d'exfiltration ont été recensés en 2025 ?
2. Quel standard du W3C lie cryptographiquement le cookie de session au composant matériel du poste ?
3. Quelle est la durée de conservation recommandée pour les journaux ?
4. Quel format d'horodatage doit être utilisé pour la traçabilité ?
5. Quel outil est utilisé pour surveiller l'exposition d'une organisation sur Internet ?

Réponses : **1.** 196 · **2.** DBSC · **3.** 6 mois · **4.** ISO 8601 · **5.** EASM

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.